

Case Study – Importance of Forensics Readiness

Working in groups of 4 students, you will analyze this case study and produce a 4-page, 2-column article answering the questions presented below. Remember that you must present a short state-of-the-art section and then your analysis.

Mission Briefing

VelocityCap, a high-frequency trading firm, reported an unauthorized API diversion of 1.2 Million Euro occurring between 02:00 and 02:15 UTC. External investigators arrived to find that the “Digital Crime Scene” had been contaminated: evidence was either missing, overwritten, or synchronized to incorrect time clocks.

Your Objective is not to find the thief. You are here to analyse the **Forensics Readiness** of VelocityCap. You must identify why the infrastructure failed to support a post-mortem analysis and design the “Forensic-by-Design” architecture required to prevent this silent void from happening again.

The Evidence Portfolio

Artifact A:

- Firewall Log: Connection accepted from 185.225.69.10 at 02:00:02 UTC.
- Web Server Log: Database query modification at 01:58:45 (Local Time).
- Audit Note: The Web Server was not using NTP. Estimated clock drift is around -125 seconds.

Artifact B:

- Incident Log: around 02:20 UTC, the System Administrator noticed high CPU usage and rebooted the server to restore service.
- All data residing in RAM memory (running processes, encryption keys, active network connections, etc.) was permanently purged by this reboot process before an image could be taken.

Other Artifacts:

- Discovery 1: A cryptocurrency miner (xmrig) was found on the App Server.
- Discovery 2: Slack logs show an administrator complaining about his salary and threatening “to break the index files.”

Task 1 – Analyse the Evidence Integrity

Evaluate the collection process:

- Calculate the corrected time for the Web Server log.
- Does the corrected time prove the Firewall connection caused the DB modification?
- Explain the “evidence admissability” implications of using “estimated clock drift” in a court of law.

The Web Server (Exhibit 2) shows the theft at 01:58:45. The Firewall (Exhibit 1) shows the attacker only entered at 02:00:02. If the Web Server has a drift of -125 seconds, what is the actual UTC time of the 1.2 Million Euro transfer? Does this corrected time align with the Firewall entry? If the logs were the only evidence in court, could you prove the attacker from 185.225.69.10 performed the POST request?

Task 2: Control Gap Mapping

Identify which ISO/IEC 27001:2022 controls failed. It is suggested to focus specifically on:

- A.8.15 (Logging)
- A.8.17 (Clock Synchronization)
- A.8.1 (User Responsibilities regarding evidence)

Look at Exhibit 2. It is a "Writable Local File". Under ISO/IEC 27001 A.8.15, explain why storing logs locally on the same server that was breached is a "Major Non-Conformance". If an attacker gains root access, what is the first thing they would do to Exhibit 2? How would a "Forensic Platform" with WORM storage prevent this?

Look at Exhibit 3. The local administrator rebooted the server at 02:20:05. List potential pieces of digital evidence that were likely in the server's RAM at 14:19:00 but were gone by 02:21:00.

Task 3: The Readiness Architecture

Redesign the system. Draft a summarised **Forensic Readiness Checklist** that includes:

- A centralized, immutable logging strategy.
- A *Live Response* policy that replaces "Rebooting" with "Memory Preservation".
- Ensuring log integrity via hashing: $H(\text{Evidence}_{\{\text{Original}\}}) = H(\text{Evidence}_{\{\text{Copy}\}})$

Exhibit 1: Network Edge (Firewall-PaloAlto-01)

Standard: UTC | Integrity: Verified via Centralized Log Server

...

[2026-02-14T02:00:01Z] SRC: 185.225.69.10 (TOR_EXIT) -> DST: 10.0.5.22 (API_GW) | PORT: 443 | ACTION: ALLOW

[2026-02-14T02:00:05Z] SRC: 185.225.69.10 (TOR_EXIT) -> DST: 10.0.5.22 (API_GW) | PORT: 443 | ACTION: ALLOW

[2026-02-14T02:15:30Z] SRC: 185.225.69.10 (TOR_EXIT) -> DST: 10.0.5.22 (API_GW) | PORT: 443 | ACTION: TERMINATE

...

Exhibit 2: Application Gateway (API_GW-Nginx)

Standard: Local CMOS (Drift Suspected) | Integrity: Writable Local File

...

14/Feb/2026:01:57:40 -0800 [INFO] Request: GET /api/v1/auth_token - User: Admin_Internal

14/Feb/2026:01:58:12 -0800 [WARN] Rate limit bypassed for Session_ID: 9982x

14/Feb/2026:01:58:45 -0800 [INFO] Request: POST /api/v1/ledger_transfer - Amount: €1,200,000 - Status: 200

...

Exhibit 3: DB Transaction Log (SQL-PROD-01)

Standard: UTC | Integrity: Database Internal Ledger

...

ID: 88219 | TS: 2026-02-14 02:01:10 | USER: API_SVC | ACTION: COMMIT | DESC: Transfer to ACCT_XXXX_99

ID: 88220 | TS: 2026-02-14 02:20:05 | USER: SYSTEM | ACTION: RESTART | DESC: System reboot by local administrator

...

Assessment criteria

- **Writing correctness and objectiveness (10%):** The report uses adequate language and presents enough details for the user to understand the ideas.
- **Characterization of state-of-the-art (30%):** the report presents current knowledge on the topic under discussion. The level of detail aligns with the depth of analysis provided.
- **Critical Analysis (50%):** The report presents sound and justified answers to the tasks of this Case Study.
- **Participation in discussion (10%):** The student shares his or her perspectives during class and engages in the debate.